

Cheval de Troie, logiciel malveillant et *Enregistreur de frappes*

Remise

- Reprenez ce même document et mettez-y vos réponses sous la forme de captures d'écran ou de phrases quand c'est demandé en rouge
- Ajoutez votre nom dans le document
- Vos captures d'écran doivent être claires et précises, montrant clairement la réponse à la question. Toute capture qui ne montre pas clairement ce qui est demandé d'afficher, ne comptera pas
- Écrivez avec un français acceptable. Assurez-vous de corriger les fautes de français et d'orthographe. Des points peuvent être enlevés dans le cas inverse

NO 1 : CRÉATION D'UN CHEVAL DE TROIE DE TYPE RAT

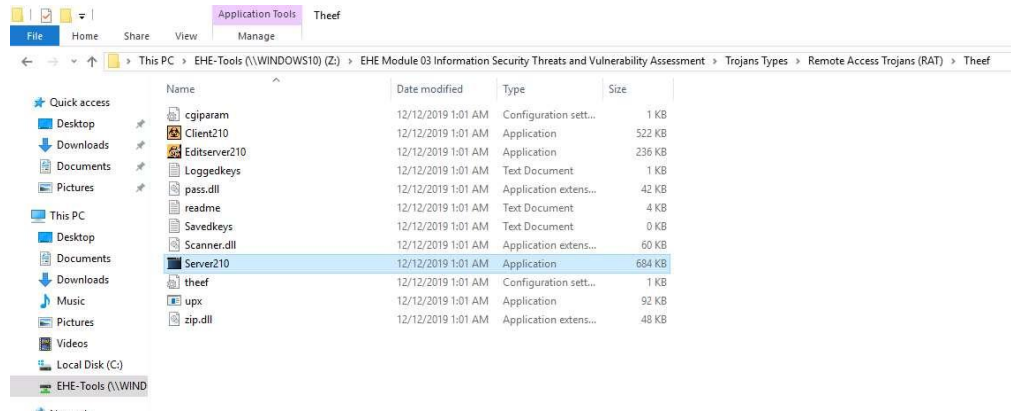
Dans cet exercice, vous allez créer le cheval de troie Theef. Ce cheval de troie est de type RAT. Il permet aux attaquants distants d'accéder au système via un port d'écoute. Theef est une application Windows pour le client et le serveur du cheval de troie. Le serveur Theef devrait être installé sur l'ordinateur cible, et le client Theef est installé du côté de l'attaquant.

La machine de l'attaquant est : **EHEV1 WINDOWS 10**

La machine de la cible : **EHEV1 WINDOWS SERVER 2016**

1. Généralement, un attaquant devrait envoyer un exécutable du serveur à la machine victime et inciter la victime à l'exécuter. Dans cet atelier, à des fins de démonstration, nous exécutons directement le fichier sur la machine victime, **Windows Server 2016**.
2. Connectez-vous sur la machine de la cible **EHEV1 WINDOWS SERVER 2016**
3. Accédez à Z:\EHE Module 03 Information Security Threats and Vulnerability Assessment\Trojans Types\Remote Access Trojans (RAT)\Theef et double-cliquez sur Server210.exe pour exécuter le cheval de Troie sur la machine victime. Le serveur devrait fonctionner en arrière-plan (il n'y aura pas d'interface graphique qui apparaîtra)

Remarque : Si une fenêtre contextuelle **Ouvrir un fichier** - Avertissement de sécurité apparaît, cliquez sur **Exécuter**.

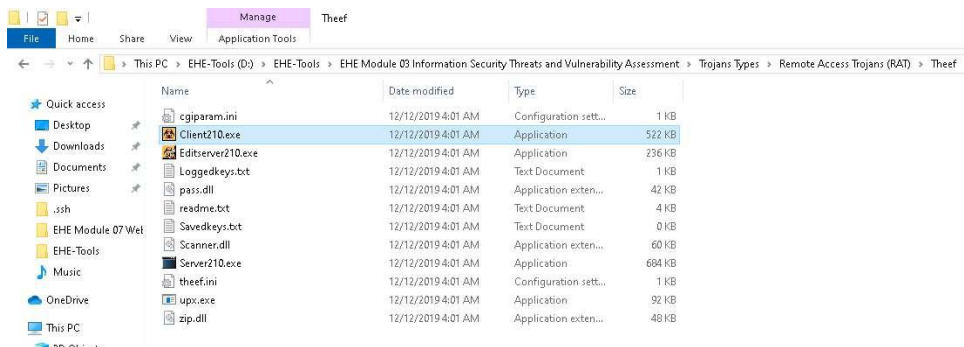


4. Lancez le navigateur chrome et laissez-le ouvert
5. Maintenant, connectez-vous sur la machine de l'attaquant **EHEV1 WINDOWS 10**

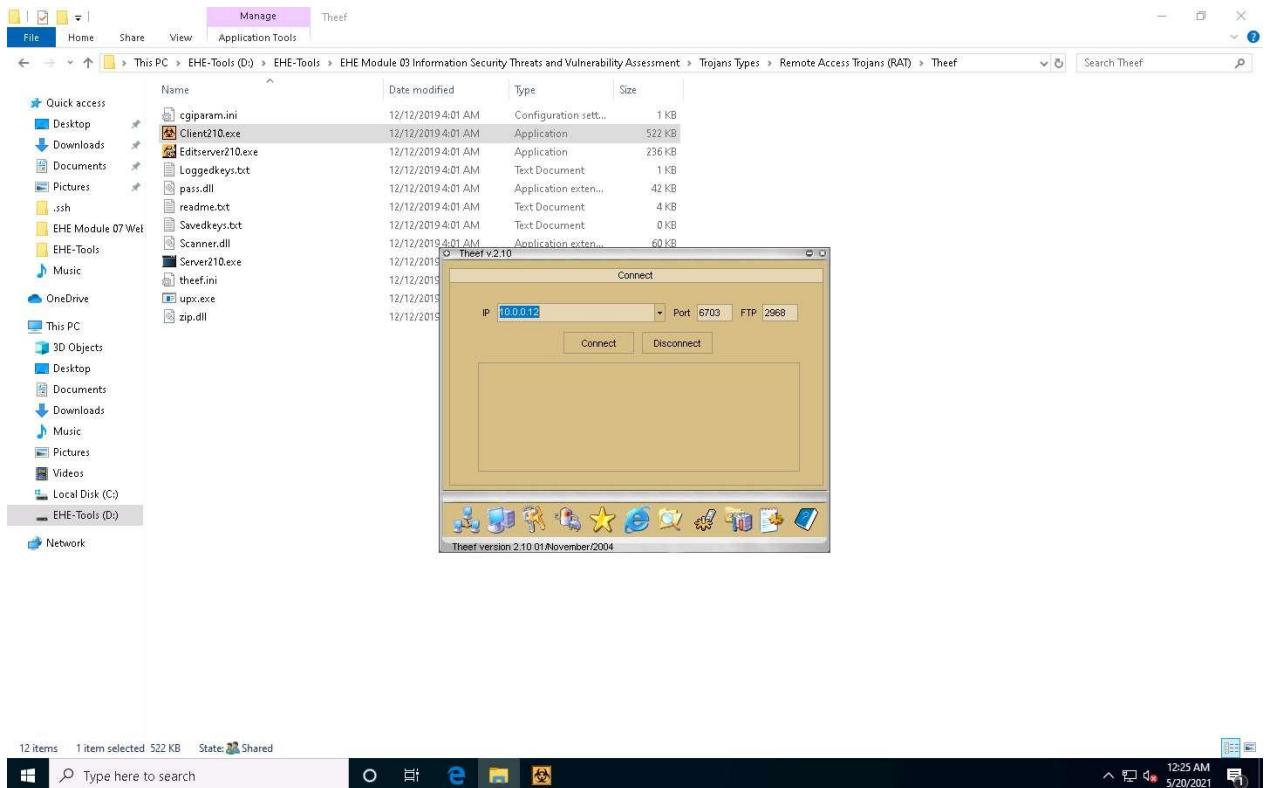
Remarque : Si l'assistant de **bienvenue dans Windows** apparaît, cliquez sur **Continuer** et dans l'assistant de **connexion avec Microsoft**, cliquez sur **Annuler**.

Remarque : L'écran Réseaux apparaît, cliquez sur **Oui** pour permettre à votre PC d'être détectable par d'autres PC et appareils sur le réseau.

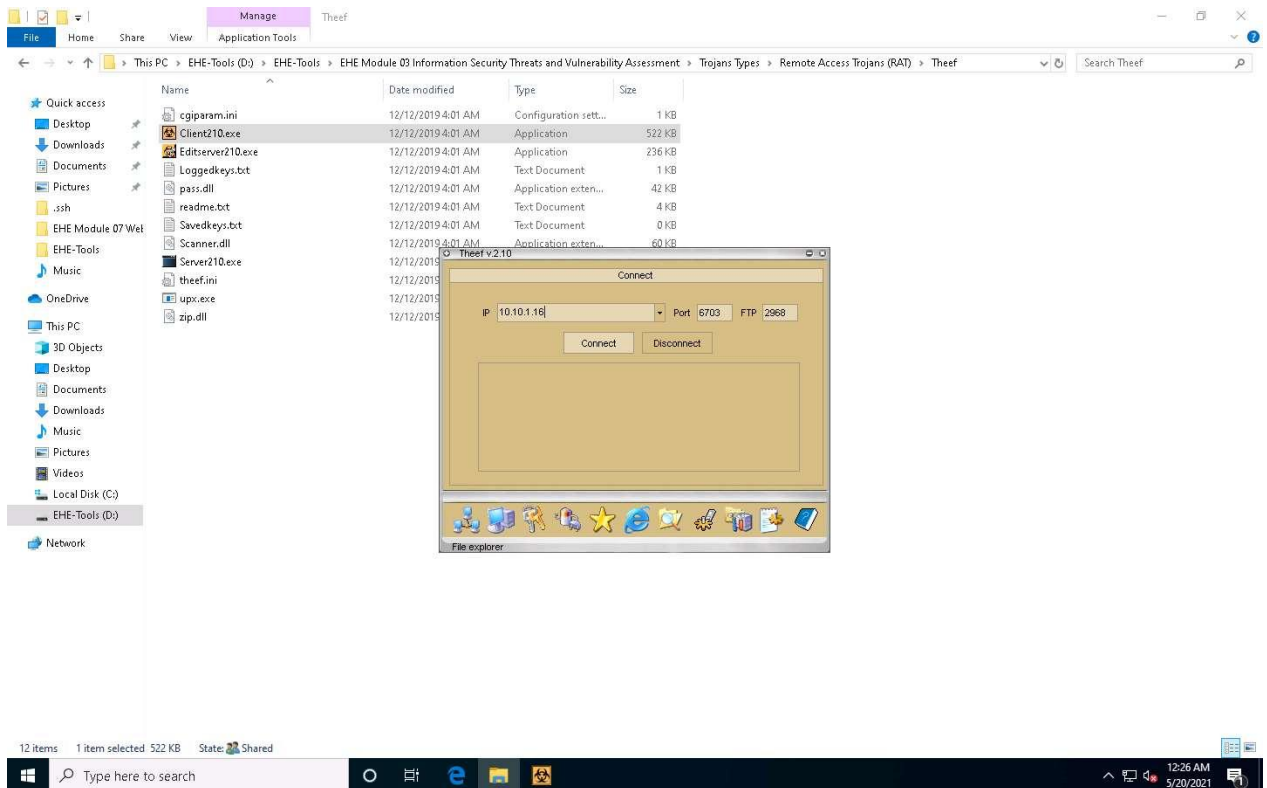
4. Accédez à **D:\EHE-Tools\EHE Module 03 Information Security Threats and Vulnerability Assessment\Trojans Types\Remote Access Trojans (RAT)\Theef** et double-cliquez sur **Client210.exe** pour accéder à distance à la machine victime.



5. La fenêtre principale **du client Theef** apparaît, comme indiqué dans la capture d'écran.



6. Le client theef va ouvrir un canal de communication avec le serveur. Pour cela, saisissez l'adresse IP de la machine cible (ici, **Windows Server 2016**) dans le champ **IP (10.10.1.16)**, et laissez les champs **Port** et **FTP** définis par défaut ; cliquez sur **Connecter** . Notez le port d'écoute du serveur, vous allez l'utiliser plus tard

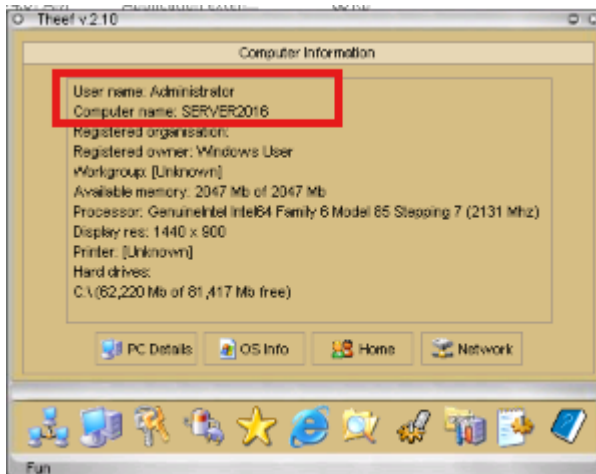


7. Désormais, à partir de **Windows 10**, vous avez réussi à établir une connexion à distance avec la machine **Windows Server 2016** .
8. Afficher les informations de la cible en cliquant sur l'icône **computer information** dans la partie inférieure de la fenêtre. Vous pouvez afficher **les détails du PC , les informations sur le système d'exploitation , l'accueil et le réseau** en cliquant sur leurs boutons respectifs.



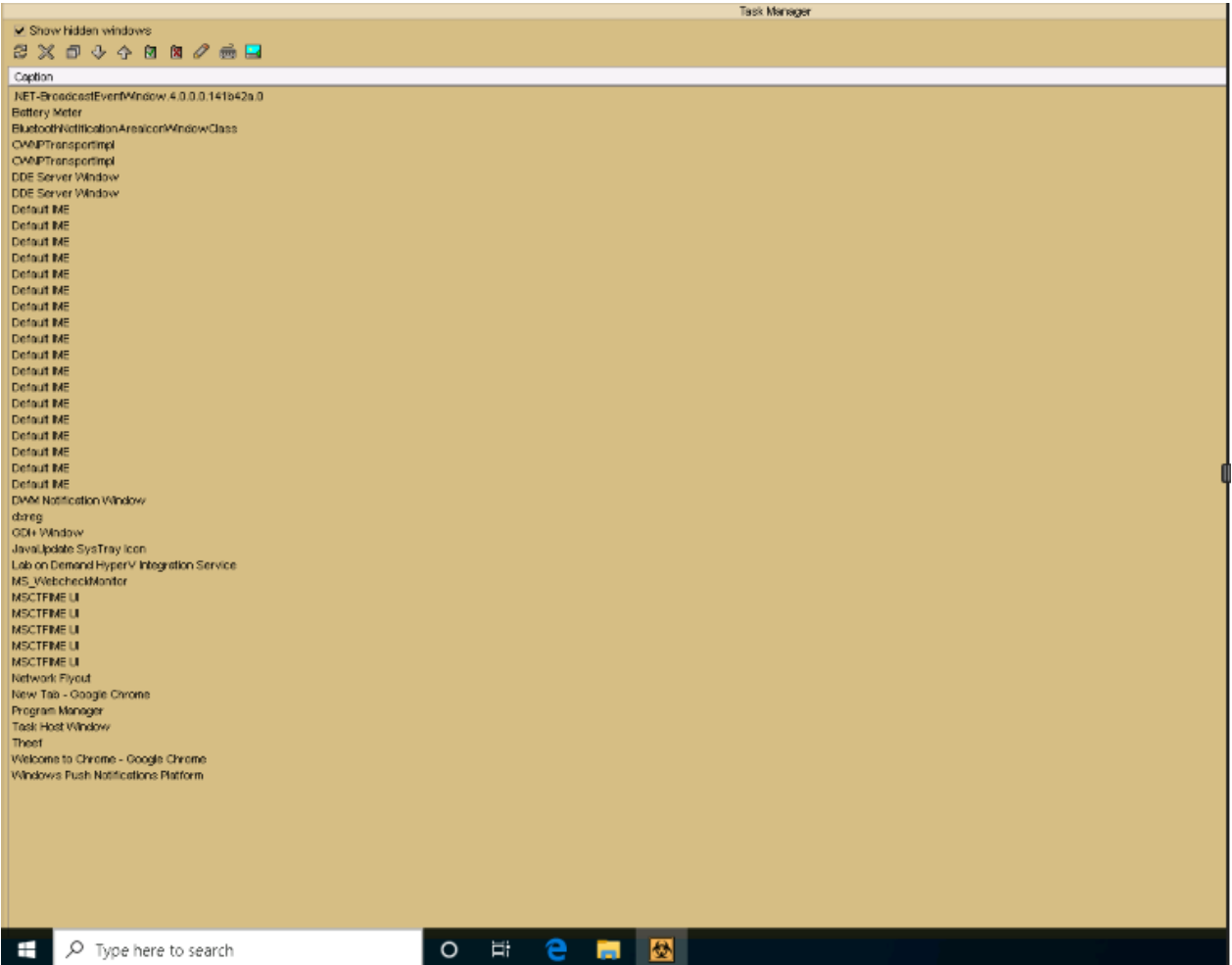
9. Dans **Informations sur l'ordinateur** , vous pouvez afficher **les détails du PC , les informations sur le système d'exploitation , l'accueil et le réseau** en cliquant sur leurs boutons respectifs.

Faites un imprime écran qui montre les détails du PC de la cible. Encadrez le nom de l'utilisateur et l'ordinateur de la victime.



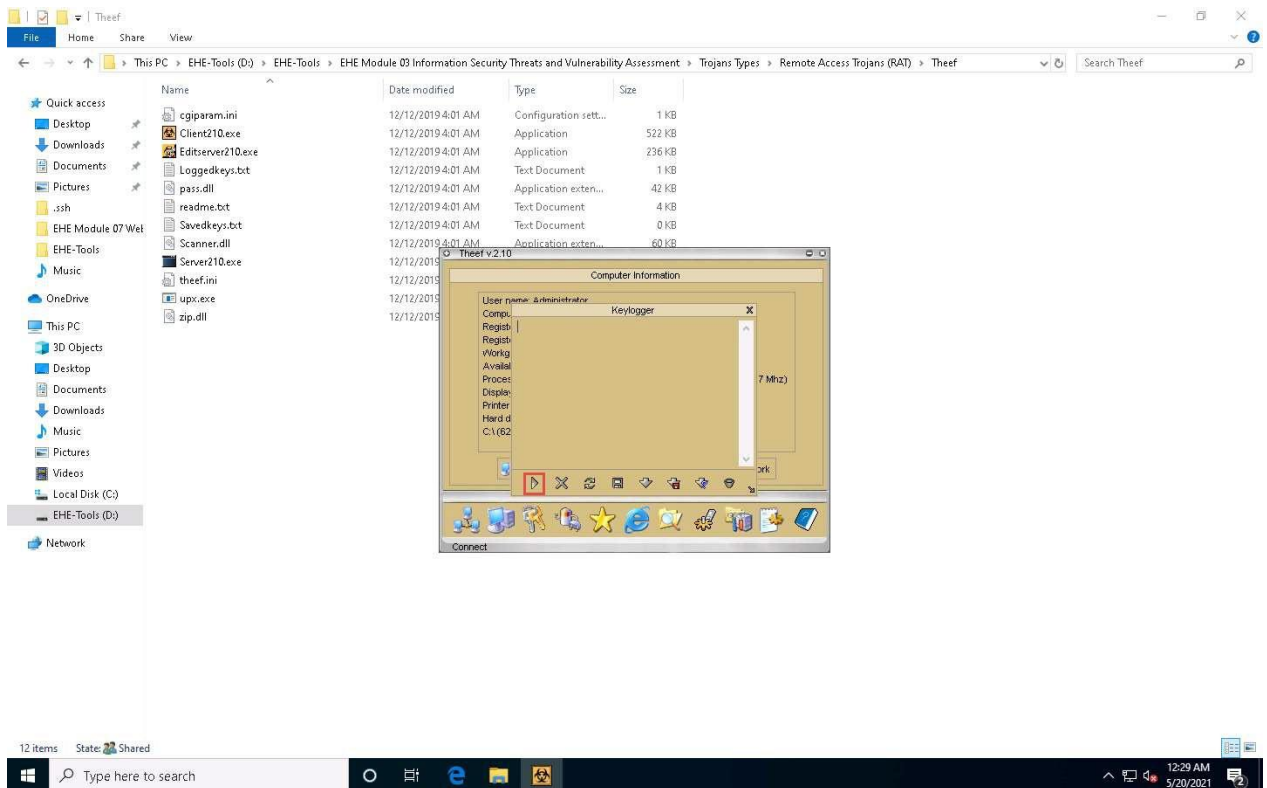
10. Cliquez sur l'icône **Spy (Espion)** pour effectuer diverses opérations sur la machine cible. Vous pouvez effectuer diverses opérations telles que enregistrer les mots de passe, afficher les processus, afficher le gestionnaire de tâches, utiliser la webcam et utiliser le microphone sur la machine victime en sélectionnant leurs options respectives.
11. Sélectionnez **task manager (Gestionnaire des tâches)** pour afficher les processus en cours d'exécution sur la machine cible. Cochez la case **show hidden windows** (afficher les fenêtres cachées) et cliquez sur **actualiser** pour voir tous les processus

Faites un imprime écran qui montre les processus de la cible



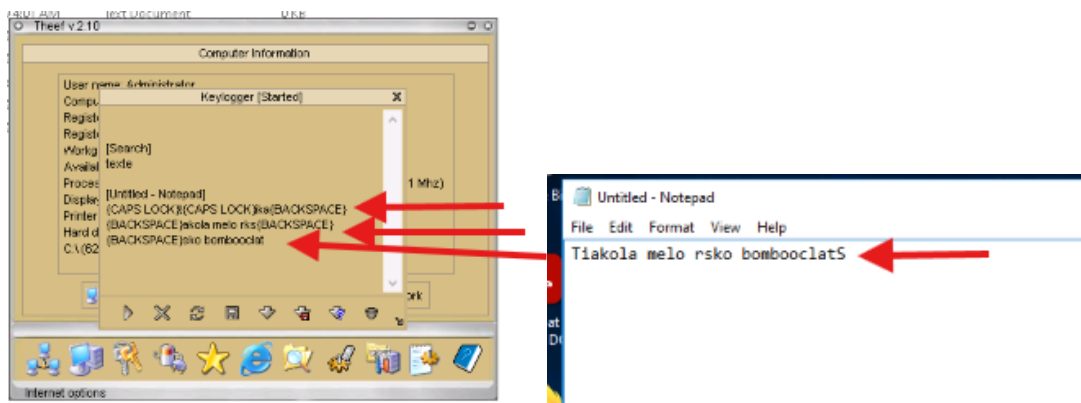
12. Cherchez le processus qui correspond au navigateur chrome et tuez-le en cliquant sur l'icône **close window**

Faites un imprime écran qui montre le processus de chrome avant qu'il soit tué dans le gestionnaire des tâches



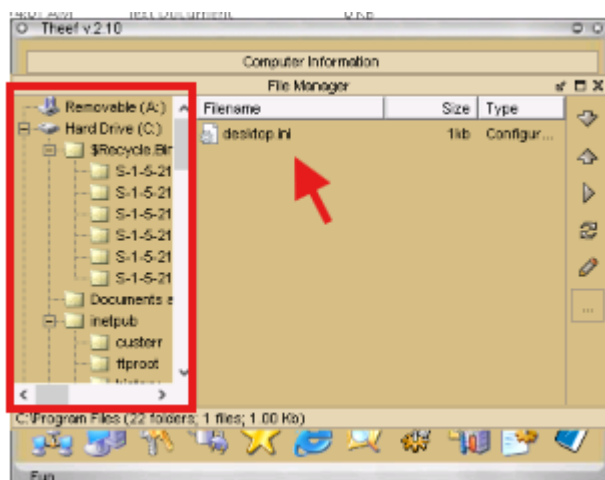
15. Basculez sur la machine **Windows Server 2016** . Ouvrez une fenêtre de navigateur et parcourez certains sites Web ou ouvrez un document texte et saisissez des informations sensibles.
16. Revenez sur la machine de l'attaquant **EHEV1 WINDOWS 10** pour revenir à la machine attaquante (**Windows 10**) afin d'afficher les frappes enregistrées de la machine victime dans la fenêtre **Theef Keylogger**.

Faites un imprime écran qui montre que vous avez réussi à capturer les informations sensibles de la victime



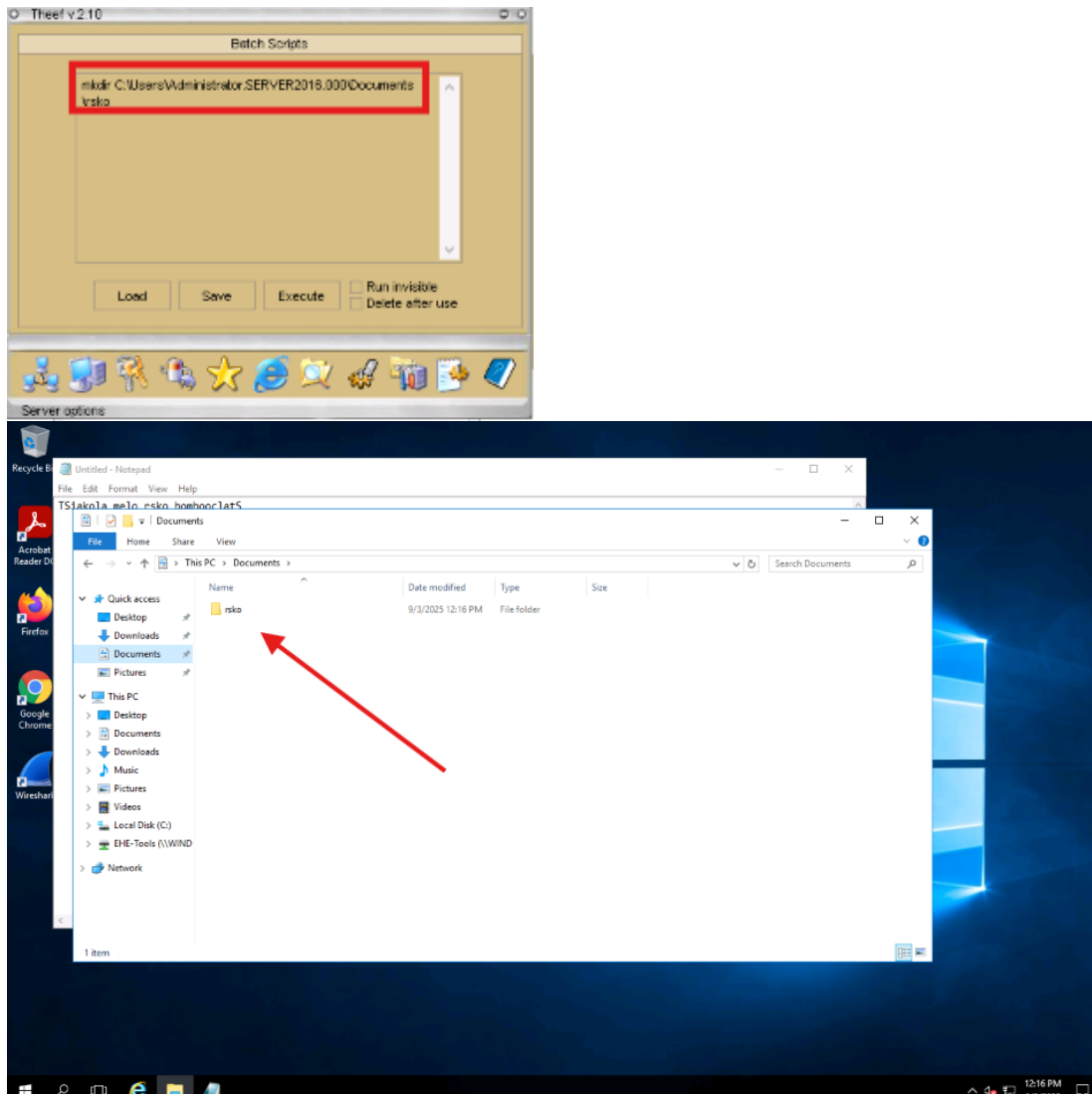
17. Fermez la fenêtre Theef **Keylogger** .
18. Explorez les fichiers de la machine cible en cliquant sur l'icône adéquate.

Faites un imprime écran qui montre les fichiers/dossiers de la cible



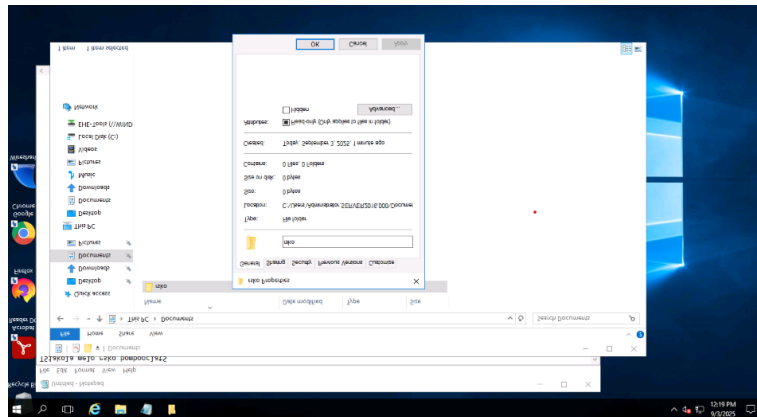
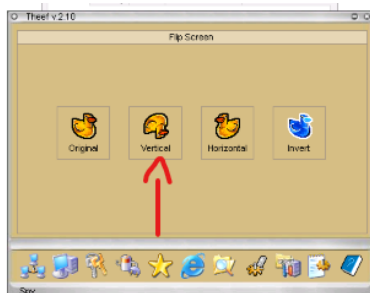
19. Cliquez sur l'icône **Control** puis **Batch script** et exécutez des commandes batch de votre choix sur la cible. Par exemple, vous pouvez créer un dossier, supprimer des fichiers, etc

Faites un imprime écran qui montre votre commande et le résultat de son exécution sur la cible



20. Explorez les autres icônes possibles du client theef et faite une activité de votre choix sur la cible.

Faites un/des imprimes écran qui montre ce que vous avez fait



Expliquez ce que vous avez fait

J'ai retourné verticalement l'écran du Windows server 2016 avec l'option Fun/Visual/Flip Screen.

NO 2 : DÉTECTION D'UN CHEVAL DE TROIE

Dans ce numéro, vous allez supprimer la connexion du cheval de troie en utilisant TCPView. TCPView est un utilitaire Windows qui affiche les connexions TCP/UDP sur la machine. TCPView montre l'état de chaque connexion (par exemple, LISTENING ou ESTABLISHED), les adresses locales et distantes associées à chaque connexion, ainsi que le port local et distant

1. Basculez sur la machine de la victime.
2. Téléchargez le logiciel TCPView
TCPView: <https://learn.microsoft.com/en-us/sysinternals/downloads/tcpview>
3. Démarrez TCPView et utilisez l'outil pour voir les connexions entrantes et sortantes.
4. Cherchez la connexion qui est établie par le cheval de troie : celle qui a comme adresse de destination (Remote address) celle de la machine de l'attaquant et utilise le port local noté précédemment.

Quelle est l'adresse Ip de la machine de l'attaquant?

10.10.1.10

Faite un imprimé écran montrant toutes les informations de cette connexion



5. Tuez le processus qui est relatif à cette connexion.
6. Vérifiez sur la machine de l'attaquant, que vous avez perdu la connexion sur le client theef. **Faite un imprimé écran montrant le message prouvant que la connexion est perdue**

